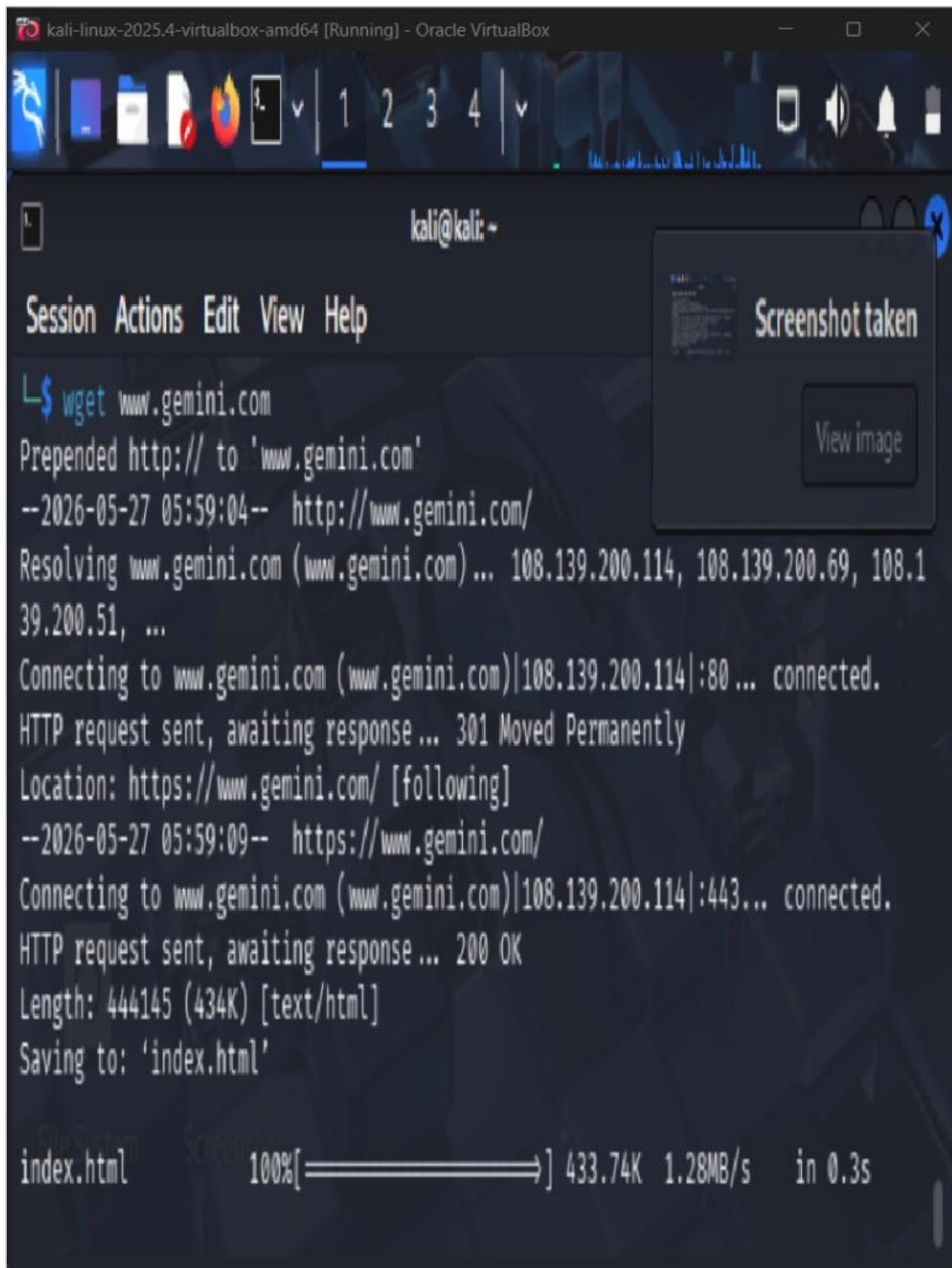


Security Assessment Report: Kali Linux & Burp Suite

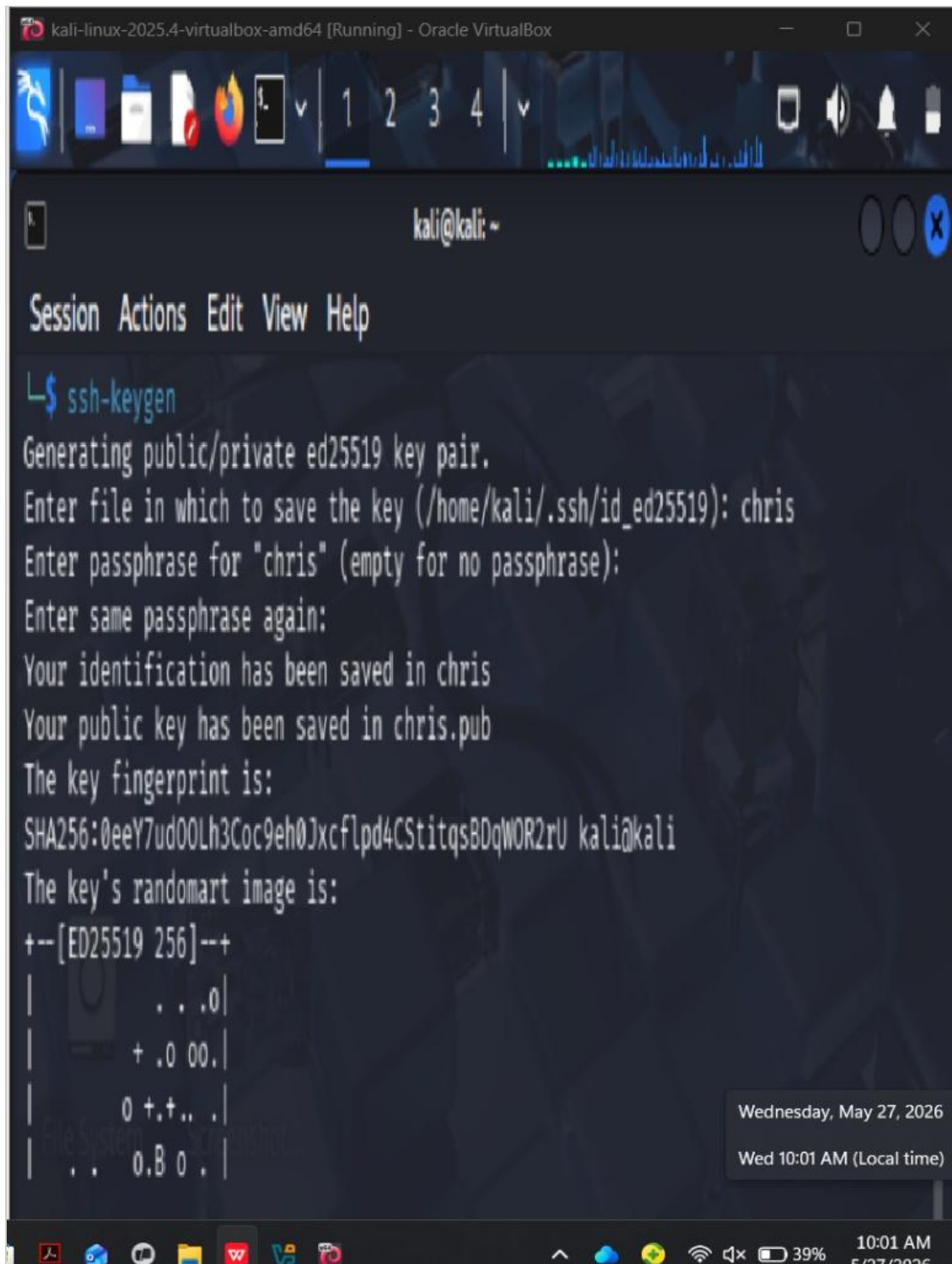
This report compiles the activities performed during the security audit in the Kali Linux virtualized environment.

Network Recon: Web Resource Fetching



```
kali-linux-2025.4-virtualbox-amd64 [Running] - Oracle VirtualBox  
kali@kali: ~  
Session Actions Edit View Help  
L$ wget www.gemini.com  
Prepended http:// to 'www.gemini.com'  
--2026-05-27 05:59:04-- http://www.gemini.com/  
Resolving www.gemini.com (www.gemini.com)... 108.139.200.114, 108.139.200.69, 108.139.200.51, ...  
Connecting to www.gemini.com (www.gemini.com)|108.139.200.114|:80 ... connected.  
HTTP request sent, awaiting response... 301 Moved Permanently  
Location: https://www.gemini.com/ [following]  
--2026-05-27 05:59:09-- https://www.gemini.com/  
Connecting to www.gemini.com (www.gemini.com)|108.139.200.114|:443... connected.  
HTTP request sent, awaiting response... 200 OK  
Length: 444145 (434K) [text/html]  
Saving to: 'index.html'  
  
index.html 100%[=====>] 433.74K 1.28MB/s in 0.3s
```

Security Setup: SSH Key Generation

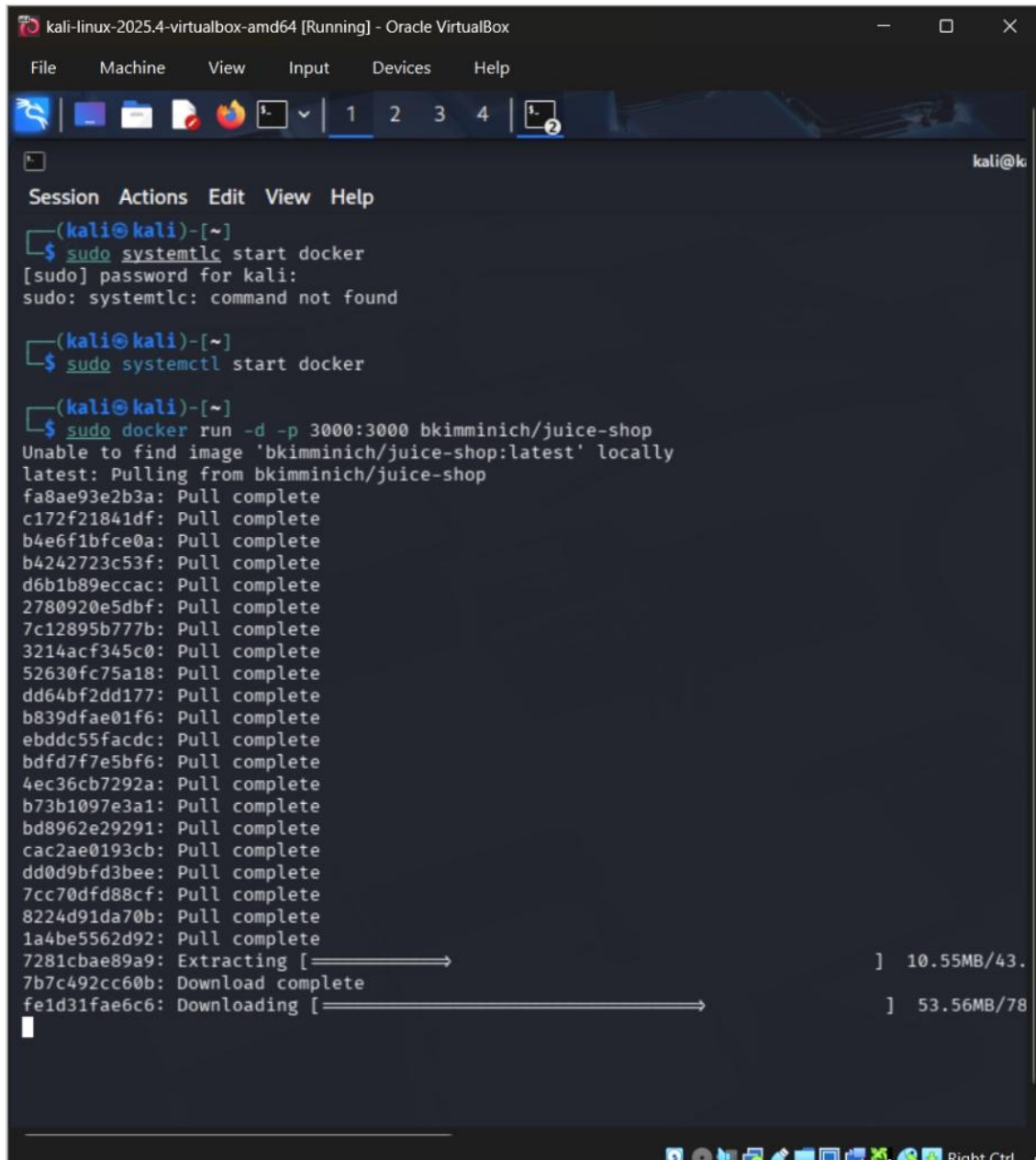


The screenshot shows a terminal window titled "kali-linux-2025.4-virtualbox-amd64 [Running] - Oracle VirtualBox". The terminal prompt is "kali@kali: ~". The user has entered the command "ssh-keygen". The output of the command is as follows:

```
Generating public/private ed25519 key pair.  
Enter file in which to save the key (/home/kali/.ssh/id_ed25519): chris  
Enter passphrase for "chris" (empty for no passphrase):  
Enter same passphrase again:  
Your identification has been saved in chris  
Your public key has been saved in chris.pub  
The key fingerprint is:  
SHA256:0eeY7ud00Lh3Coc9eh0Jxcflpd4CStitqsBDqW0R2rU kali@kali  
The key's randomart image is:  
+--[ED25519 256]--+  
|                . . .0|  
|                + .0 00.|  
|                0 +.+. .|  
|                . . 0.B 0 .|
```

A date and time stamp is visible in the bottom right corner of the terminal window: "Wednesday, May 27, 2026" and "Wed 10:01 AM (Local time)".

Environment Setup: Pulling Docker Image



The screenshot shows a terminal window titled "kali-linux-2025.4-virtualbox-amd64 [Running] - Oracle VirtualBox". The terminal displays the following commands and output:

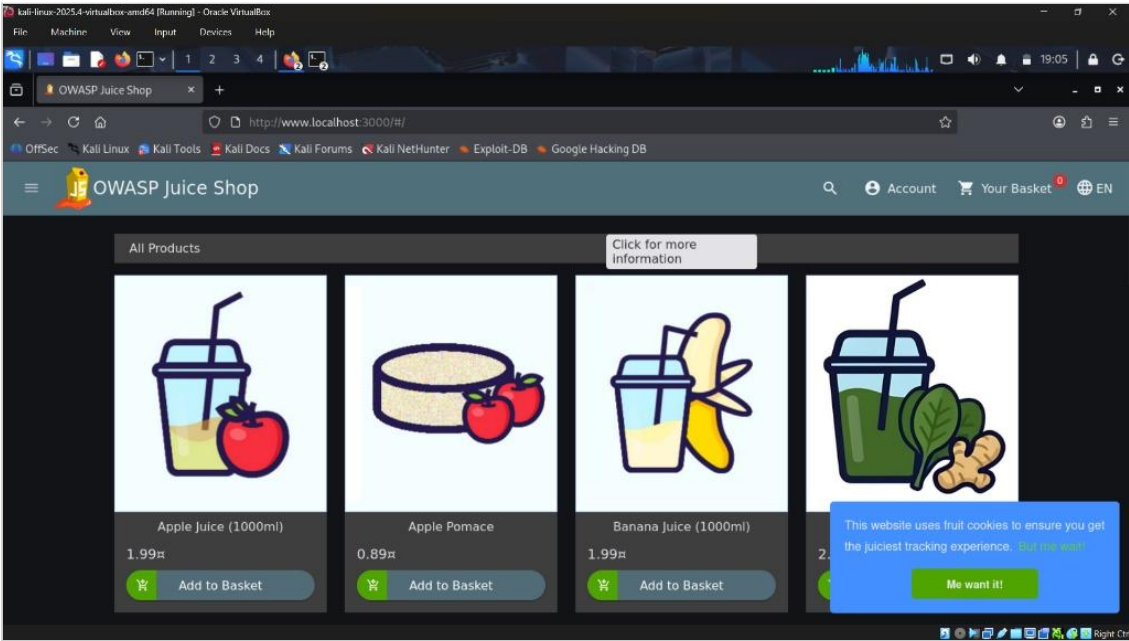
```
(kali@kali)-[~]
$ sudo systemctl start docker
[sudo] password for kali:
sudo: systemctl: command not found

(kali@kali)-[~]
$ sudo systemctl start docker

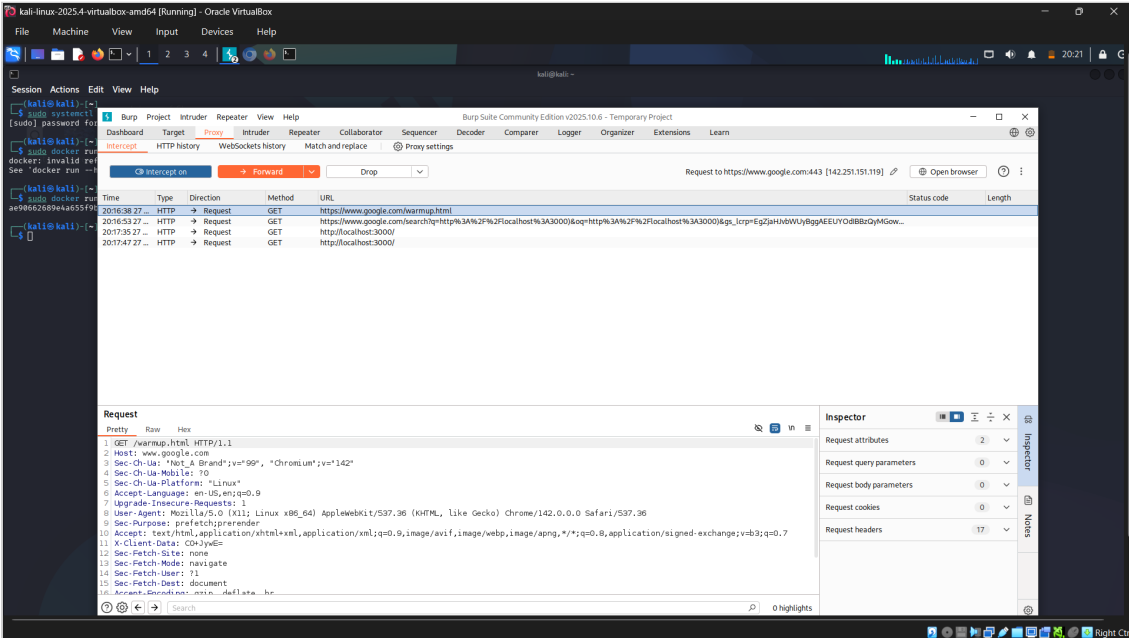
(kali@kali)-[~]
$ sudo docker run -d -p 3000:3000 bkimminich/juice-shop
Unable to find image 'bkimminich/juice-shop:latest' locally
latest: Pulling from bkimminich/juice-shop
fa8ae93e2b3a: Pull complete
c172f21841df: Pull complete
b4e6f1bfce0a: Pull complete
b4242723c53f: Pull complete
d6b1b89eccac: Pull complete
2780920e5dbf: Pull complete
7c12895b777b: Pull complete
3214acf345c0: Pull complete
52630fc75a18: Pull complete
dd64bf2dd177: Pull complete
b839dfae01f6: Pull complete
ebddc55facdc: Pull complete
bdfd7f7e5bf6: Pull complete
4ec36cb7292a: Pull complete
b73b1097e3a1: Pull complete
bd8962e29291: Pull complete
cac2ae0193cb: Pull complete
dd0d9bfd3bee: Pull complete
7cc70dfd88cf: Pull complete
8224d91da70b: Pull complete
1a4be5562d92: Pull complete
7281cbae89a9: Extracting [=====] 10.55MB/43.
7b7c492cc60b: Download complete
fe1d31fae6c6: Downloading [=====] 53.56MB/78
```

The terminal window includes a menu bar with "File", "Machine", "View", "Input", "Devices", and "Help". Below the menu bar is a toolbar with icons for various functions. The terminal output shows the process of starting the Docker service and pulling the "bkimminich/juice-shop:latest" image from a remote repository. The image is pulled in layers, with progress bars indicating the download status of each layer.

Target Application: OWASP Juice Shop



Traffic Control: Burp Suite Proxy Active



Analysis: HTTP Request & Header Inspection

kali-linux-2025.4-virtualbox-amd64 [Running] - Oracle VirtualBox

File Machine View Input Devices Help

1 2 3 4

Project /home/kali

Intercept HTTP history WebSockets history Match and replace Proxy settings

Filter settings: Hiding CSS and image content; hiding specific extensions Filter on

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title
1	https://www.google.com	GET	/warmup.html			404	1782	HTML	html	Error
2	https://www.google.com	GET	/search?q=http%3A%2F%2Flocalh...	✓		200	93735	HTML		Googl
3	http://localhost:3000	GET	/			200	10370	HTML		OWA:
4	http://localhost:3000	GET	/			200	10370	HTML		OWA:
5	http://localhost:3000	GET	/			200	10370	HTML		OWA:
22	http://localhost:3000	GET	/socket.io/?EIO=4&transport=pollin...	✓		200	326	text	io/	
23	http://localhost:3000	GET	/assets/i18n/en.json			200	35947	JSON	json	
24	http://localhost:3000	GET	/rest/admin/application-version			200	404	JSON		
25	http://localhost:3000	GET	/rest/admin/application-configurati...			200	23902	JSON		
26	http://localhost:3000	GET	/api/Challenges/?name=Score%20...	✓		200	862	JSON		
27	http://localhost:3000	GET	/rest/languages			200	4603	JSON		
28	http://localhost:3000	GET	/rest/admin/application-version			304	304			

Request

Pretty Raw Hex

```
1 GET /rest/admin/application-versio
2 n HTTP/1.1
3 Host: localhost:3000
4 sec-ch-ua-platform: "Linux"
5 Accept-Language: en-US,en;q=0.9
6 Accept: application/json, text/plain, */*
7 sec-ch-ua: "Not_A Brand";v="99", "Chromium";v="142"
8 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/142.0.0.0 Safari/537.36
9 sec-ch-ua-mobile: ?0
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: cors
12 Sec-Fetch-Dest: empty
13 Referer: http://localhost:3000/
14 Accept-Encoding: gzip, deflate, br
15 Connection: keep-alive
```

Response

Pretty Raw Hex

```
1 HTTP/1.1 200 OK
2 Access-Control-Allow-Origin: *
3 X-Content-Type-Options: nosniff
4 X-Frame-Options: SAMEORIGIN
5 Feature-Policy: payment 'self'
6 X-Recruiting: /#/jobs
7 Content-Type: application/json; charset=utf-8
8 Content-Length: 20
9 ETag: w/"14"+EBpZnful93JzIOBjXsY1+KveN8"
10 Vary: Accept-Encoding
11 Date: Thu, 28 May 2026 00:24:02 GMT
12 Connection: keep-alive
13 Keep-Alive: timeout=5
14
15 {
16   "version": "20.0.0"
17 }
```

Inspector

Request attributes 2

Request headers 13

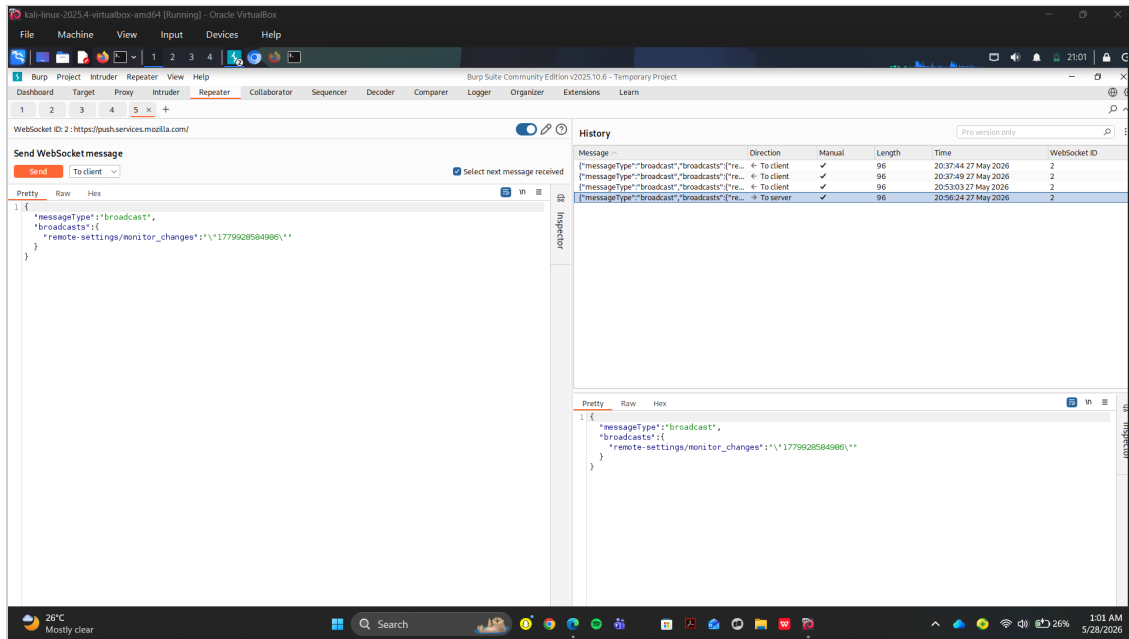
Response headers 12

Right Ctrl

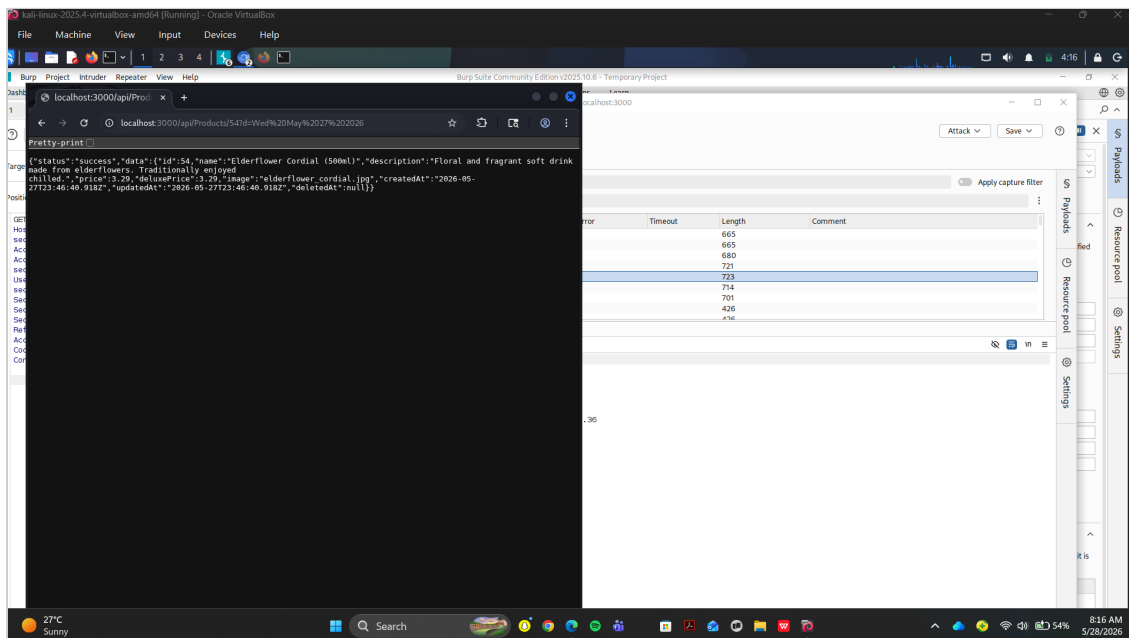
[illegible]

The screenshot displays the Burp Suite application window. At the top, the title bar reads 'kali-linux-2023.4-virtualbox-amd64 [Running] - Oracle VM VirtualBox'. The main menu includes File, Machine, View, Input, Devices, and Help. Below the menu is a toolbar with icons for various functions. The central pane is divided into several tabs: Dashboard, Target, Proxy, Intruder, Repeater, Collaborator, Sequencer, Decoder, Comparer, Logger, Organizer, Extensions, and Learn. The 'Intercept' tab is active, showing a list of intercepted HTTP requests. The table has columns for Time, Type, Direction, Method, URL, Status code, and Length. The first request is a GET request to 'http://localhost:3000/socket.io/?EIO=4&transport=websocket&sid=CHWVY-N_xf22gzAAAE' with a status code of 1. The second request is a POST request to 'http://localhost:3000/test/user/login' with a status code of 401. The third request is a GET request to 'http://localhost:3000/test/user/whoami' with a status code of 200. The fourth request is a GET request to 'http://localhost:3000/test/user/whoami?fields=email' with a status code of 200. The fifth request is a GET request to 'http://localhost:3000/socket.io/?EIO=4&transport=websocket&sid=CHWVY-N_xf22gzAAAE' with a status code of 200. The bottom pane shows the 'Raw' view of the selected request, displaying a JSON message: '{"messageType": "broadcast", "broadcasts": [{"remoteSettings": "monitor_changes": {"1779028584906": {}}}]'.

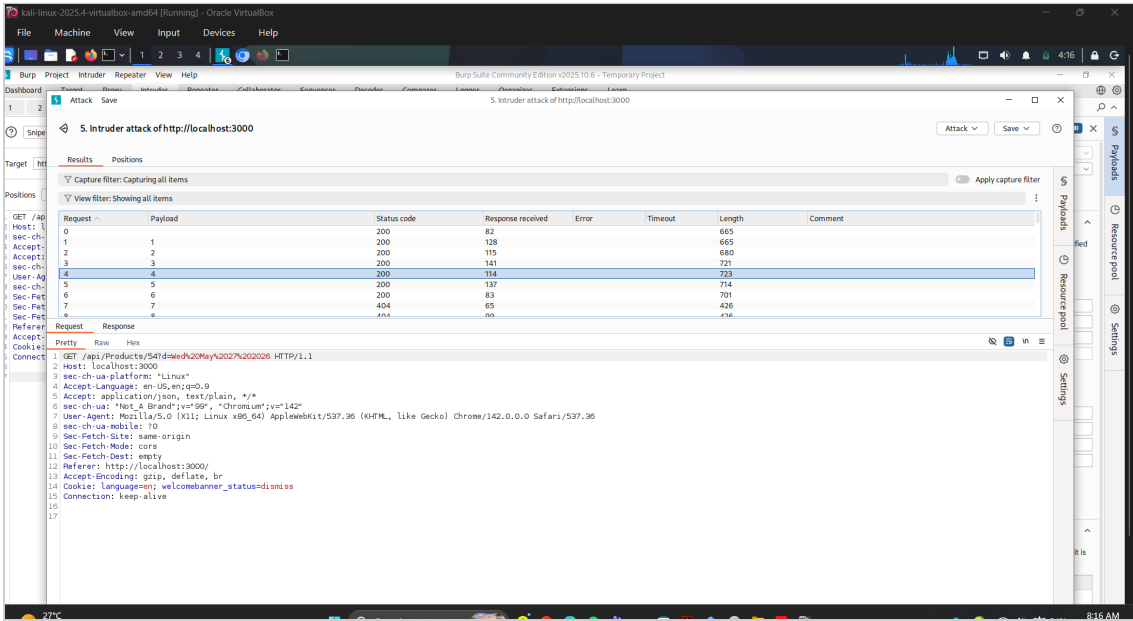
Exploitation/Testing: WebSocket Repeater



API Analysis: Product Data Endpoint



Automation: Intruder Fuzzing Results



The screenshot displays the Burp Suite interface during an intruder attack. The main window shows the 'Results' tab, which contains a table of attack results. The table has columns for Request, Payload, Status code, Response received, Error, Timeout, Length, and Comment. The results show a series of requests and responses, with the final response being a 200 status code. The 'Request' column shows the full HTTP request, including headers and body. The 'Payload' column shows the specific payload used in the attack. The 'Status code' column shows the response status code. The 'Response received' column shows the response body. The 'Error' column shows any errors encountered. The 'Timeout' column shows the time taken for the request to complete. The 'Length' column shows the size of the response. The 'Comment' column shows any additional information.

Request	Payload	Status code	Response received	Error	Timeout	Length	Comment
0		200	82			665	
1	1	200	128			665	
2	2	200	115			680	
3	3	200	141			721	
4	4	200	114			723	
5	5	200	137			714	
6	6	200	83			701	
7	7	404	65			426	
8	8	200	nn			476	

The 'Request' column shows the full HTTP request, including headers and body. The 'Payload' column shows the specific payload used in the attack. The 'Status code' column shows the response status code. The 'Response received' column shows the response body. The 'Error' column shows any errors encountered. The 'Timeout' column shows the time taken for the request to complete. The 'Length' column shows the size of the response. The 'Comment' column shows any additional information.

Request: GET /api/products/547d9e4h20May%2027%202026 HTTP/1.1
Host: localhost:3000
sec-ch-ua-platform: Linux
Accept-Language: en-US,en;q=0.9
Accept: application/json, text/plain, */*
sec-ch-ua: "Not A Brand";v="99", "Chrome";v="142"
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/142.0.0.0 Safari/537.36
sec-ch-ua-mobile: ?0
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: http://localhost:3000/
Accept-Encoding: gzip, deflate, br
Cookie: language=en; welcomebanner_status=dismiss
Connection: keep-alive